SENTINEL | OT

PROJECT SCOPE

# Cedar Ridge Regional Water Authority: Full External Assessment and Remediation

| | |
|---|---|
| DOCUMENT | Project Scope and Statement of Work |
| DATE | April 22, 2026 |
| PREPARED BY | Sentinel OT |
| CLASSIFICATION | Confidential |
| REFERENCE | Report ID: pbcwud_cedar-ridge_sample_2026-04-15 |

## Background

On April 15, 2026, Sentinel OT delivered a Vulnerability Intelligence Report to Cedar Ridge Regional Water Authority (CRRWA) identifying two Rockwell Automation CompactLogix 1769-L18ER programmable logic controllers directly exposed to the public internet at the Cedar Ridge Water Treatment Plant. The assessment identified three confirmed Critical vulnerabilities (CVSS 9.8), all remotely exploitable without authentication, plus three informational findings.

One of the three Critical vulnerabilities, CVE-2021-22681, is listed in the CISA Known Exploited Vulnerabilities catalog. The federal remediation deadline has already passed.

This document defines the scope, deliverables, timeline, and cost for a full external assessment and remediation engagement. It is designed to be attached to a grant application under the State and Local Cybersecurity Grant Program (SLCGP) or the Drinking Water State Revolving Fund (DWSRF).

## Engagement Objectives

1. **Eliminate internet exposure** of all industrial control system assets at the Cedar Ridge Water Treatment Plant.
2. **Remediate all three Critical CVEs** identified in the April 15 intelligence report, or document formal risk acceptance with compensating controls where hardware limitations prevent patching.
3. **Establish a defensible network architecture** between the Microhard cellular gateway and the PLC subnet, replacing the current NAT/port-forwarding model.
4. **Produce compliance-grade documentation** that satisfies AWIA Section 2013, IEC 62443, and NIST SP 800-82 Rev 3 requirements.
5. **Deliver a validated, monitored state** with evidence that all findings have been addressed and ongoing monitoring is operational.

# Scope of Work

## Phase 1: Immediate Compensating Controls (Days 1 to 3)

No plant downtime required. All work performed at the network edge.

| TASK | DESCRIPTION | ADDRESSES |
|---|---|---|
| 1.1 | Configure access control lists on the Microhard cellular gateway to drop all inbound traffic to ports 44818/tcp and 44818/udp from any source other than a designated operator jump host | CVE-2021-22681, CVE-2022-1161 |
| 1.2 | Block inbound traffic to ports 80/tcp and 443/tcp on both public IPs at the gateway | CVE-2019-10952 |
| 1.3 | Block inbound traffic to port 602/tcp on Device B (XetaWave radio management) | Informational 1 |
| 1.4 | Disable FTP (21/tcp) and Telnet (23/tcp) services on the Microhard gateway | Informational 3 |
| 1.5 | Rotate all credentials on the Microhard gateway, PLC web interfaces, and SSH services. Replace default “UserDevice” credentials with strong, unique passwords | Informational 3, general hardening |
| 1.6 | Disable the open DNS resolver on port 53/tcp or restrict to internal interface only | Informational 2 |

**Deliverable:** Compensating Controls Verification Report confirming all six tasks are complete, with before-and-after evidence from passive scan validation.

## Phase 2: Comprehensive On-Site Assessment (Days 4 to 14)

On-site work at the Cedar Ridge Water Treatment Plant. Conducted by a qualified OT security assessor.

| TASK | DESCRIPTION |
|---|---|
| 2.1 | Validate all passive intelligence findings against physical infrastructure. Confirm device inventory, firmware versions, and network topology. |
| 2.2 | Map the complete OT network architecture: controllers, HMIs, historians, cellular gateways, radio links, and any additional field devices not visible from passive reconnaissance. |
| 2.3 | Perform controller integrity baseline. Compare the running program on each PLC against the last known-good backup from the plant integrator. Document the comparison result. |
| 2.4 | Assess the Microhard gateway configuration for additional misconfigurations not visible externally (internal firewall rules, VPN configuration, logging posture). |
| 2.5 | Identify any additional vulnerabilities not visible through passive reconnaissance (internal-only services, HMI exposure, historian database access controls). |
| 2.6 | Conduct AWIA-aligned risk and resilience assessment for cybersecurity components, per Section 2013 requirements. |
| 2.7 | Interview plant operations staff to document current access procedures, change management practices, and incident response capabilities. |

**Deliverable:** Comprehensive Assessment Report including validated asset inventory, network architecture diagram, controller integrity baseline results, and a complete vulnerability register with risk ratings.

## Phase 3: Network Architecture Remediation (Days 15 to 45)

Requires coordination with plant operations for scheduled maintenance windows.

| TASK | DESCRIPTION | ESTIMATED DOWNTIME |
|---|---|---|
| 3.1 | Replace the current NAT/port-forwarding model on the Microhard gateway with a VPN-only architecture. All remote access will terminate through an encrypted tunnel with certificate-based authentication. | 4 to 6 hours |
| 3.2 | Deploy an industrial firewall (e.g., Cisco ISA 3000, Fortinet FortiGate Rugged, or Tofino) between the cellular gateway and the PLC subnet. Configure zone-based rules per IEC 62443-3-3 SR 5.1. | 2 to 4 hours |
| 3.3 | Implement network segmentation between the PLC subnet, HMI/SCADA subnet, and any corporate or maintenance networks. | 2 to 4 hours |
| 3.4 | Establish a secure remote access jump host for authorized operator and integrator access. Require multi-factor authentication. | No downtime |

**Deliverable:** Network Architecture Remediation Report with updated network diagrams, firewall rule documentation, VPN configuration records, and verification test results.

## Phase 4: Controller Remediation (Days 30 to 60)

Requires scheduled maintenance windows. Controllers updated in sequence, never simultaneously.

| TASK | DESCRIPTION | ESTIMATED DOWNTIME PER CONTROLLER |
|---|---|---|
| 4.1 | Coordinate with Rockwell Automation to identify the latest supported firmware for the 1769-L18ER platform. Validate compatibility with the existing Studio 5000 project. | No downtime (planning) |
| 4.2 | Upgrade controller firmware to the latest supported version. If the platform supports CIP Security (Logix Designer v33 or later), enable authentication and integrity on EtherNet/IP sessions. | 2 to 4 hours per controller |
| 4.3 | If CIP Security is not supported on the 1769-L18ER platform, document formal risk acceptance with compensating controls per IEC 62443-3-3 SR 1.1 and include controller replacement in the FY2027 capital request. | No downtime |
| 4.4 | Enable Controller Change Detection if supported by the firmware version. Establish a golden image baseline and a monthly comparison procedure. | 30 minutes per controller |

| TASK | DESCRIPTION | ESTIMATED DOWNTIME PER CONTROLLER |
|---|---|---|
| 4.5 | Rotate all cached authentication keys on both controllers. | 30 minutes per controller |

**Deliverable:** Controller Remediation Report with firmware upgrade records, CIP Security configuration evidence (or formal risk acceptance), and golden image baseline documentation.

## Phase 5: Documentation and Compliance (Days 45 to 75)

| TASK | DESCRIPTION |
|---|---|
| 5.1 | Produce a complete AWIA-compliant Risk and Resilience Assessment document incorporating all findings, remediations, and residual risks. |
| 5.2 | Produce an AWIA-compliant Emergency Response Plan update reflecting the new network architecture and access procedures. |
| 5.3 | Produce a Standards Compliance Mapping document showing alignment with IEC 62443-3-3, NIST SP 800-82 Rev 3, and CISA CPG 2.0. |
| 5.4 | Deliver an Executive Summary suitable for presentation to the CRRWA Board of Directors and municipal counsel. |
| 5.5 | Conduct a closeout briefing with plant operations staff covering the changes made, new access procedures, and ongoing monitoring requirements. |

**Deliverable:** Complete compliance documentation package (RRA, ERP update, standards mapping, executive summary).

## Phase 6: Ongoing Monitoring (Month 3 onward)

| TASK | DESCRIPTION |
|---|---|
| 6.1 | Continuous passive monitoring of all CRRWA internet-facing assets to detect any re-exposure or new services appearing on public IPs. |

| TASK | DESCRIPTION |
|---|---|
| 6.2 | Vulnerability alerting for all Rockwell Automation products deployed at the facility, including new CVE publications, CISA advisories, and KEV catalog additions. |
| 6.3 | Quarterly posture report summarizing monitoring findings, any new advisories, and recommended actions. |

**Deliverable:** Quarterly Monitoring Reports. Ongoing alert notifications delivered within 24 hours of relevant advisory publication.

## Timeline

| PHASE | DURATION | DEPENDENCIES |
|---|---|---|
| Phase 1: Compensating Controls | Days 1 to 3 | None. Can begin immediately upon contract execution. |
| Phase 2: On-Site Assessment | Days 4 to 14 | Phase 1 complete. Plant access coordinated with CRRWA operations. |
| Phase 3: Network Remediation | Days 15 to 45 | Phase 2 complete. Maintenance windows scheduled with operations. |
| Phase 4: Controller Remediation | Days 30 to 60 | Phase 2 complete. Rockwell coordination initiated. Overlaps with Phase 3. |
| Phase 5: Documentation | Days 45 to 75 | Phases 3 and 4 substantially complete. |
| Phase 6: Monitoring | Month 3 onward | Phases 1 through 5 complete. Continuous. |

**Total engagement duration (Phases 1 through 5): approximately 75 calendar days.**

# Cost Estimate

| PHASE | DESCRIPTION | ESTIMATED COST |
|---|---|---|
| Phase 1 | Compensating Controls | $2,500 |
| Phase 2 | Comprehensive On-Site Assessment | $8,500 |
| Phase 3 | Network Architecture Remediation | $6,500 |
| Phase 4 | Controller Remediation | $4,500 |
| Phase 5 | Documentation and Compliance | $3,500 |
| **Phases 1 through 5** | **Total Project Cost** | **$25,500** |
| Phase 6 | Ongoing Monitoring (annual) | $3,600/year |

Hardware costs (industrial firewall, VPN appliance, jump host infrastructure) are not included in the above estimate and will be quoted separately based on the selected products identified during Phase 2.

## Grant Eligibility

This engagement falls within the eligible activities defined by the State and Local Cybersecurity Grant Program (SLCGP) under the Infrastructure Investment and Jobs Act of 2021. Eligible categories include:

- **Cybersecurity assessments** (Phases 1 and 2)
- **Cybersecurity planning** (Phase 5)
- **Implementation of security measures** (Phases 3 and 4)
- **Addressing imminent cybersecurity threats** (Phase 1, given CISA KEV status of CVE-2021-22681)

The Drinking Water State Revolving Fund (DWSRF) and the Water Infrastructure Finance and Innovation Act (WIFIA) program may also provide funding pathways for the infrastructure components of this engagement.

Sentinel OT provides grant application support at no additional cost during the engagement, including narrative drafting, cost justification documentation, and coordination with the state administrative agency (SAA).

# Assumptions and Exclusions

## Assumptions

- CRRWA will provide physical access to the Cedar Ridge Water Treatment Plant for on-site assessment work during Phase 2.
- CRRWA will coordinate maintenance windows for Phases 3 and 4 with plant operations staff.
- The existing plant integrator will be available to provide the last known-good controller program backup for integrity baseline comparison.
- Remote access to the Microhard gateway for Phase 1 compensating controls will be provided within 24 hours of contract execution.

## Exclusions

- Active penetration testing or exploitation of any vulnerability.
- Replacement hardware procurement (quoted separately).
- Modifications to the SCADA/HMI application or controller logic beyond firmware updates and security configuration.
- Physical security assessments.
- IT network assessments outside the OT/SCADA environment.
- Legal or regulatory filing on behalf of CRRWA.

# Acceptance Criteria

Each phase is considered complete when the corresponding deliverable has been submitted to CRRWA and accepted in writing. Acceptance is based on the following criteria:

1. All tasks listed for the phase have been completed or a documented exception has been agreed upon.
2. Before-and-after evidence demonstrates that each finding addressed by the phase has been remediated or mitigated.
3. Documentation meets the standards referenced in Phase 5 (AWIA, IEC 62443, NIST SP 800-82).
4. CRRWA operations staff have been briefed on any changes affecting daily operations.

# Contact

| ROLE | NAME | CONTACT |
|---|---|---|
| Sentinel OT Project Lead | Johnny Tran | johnny@sentinelot.com |
| Sentinel OT Technical Lead | To be assigned | — |
| CRRWA Point of Contact | To be designated | — |

*Sample document. Cedar Ridge Regional Water Authority is a fictional operator used to illustrate the format and depth of a Sentinel OT project scope. No real utility, facility, or IP address is depicted. This document accompanies the sample Vulnerability Intelligence Report (Report ID: pbcwud_cedar-ridge_sample_2026-04-15).*